

Threat Hunt Report - Malware Families Analysis (OCT 2025)

Source: <https://thehackernews.com/2025/10/google-identifies-three-new-russian.html>

DATE: 27/10/2025

Reported Malware Families:

Step 1 - Extract 2-3 IOCs:

Malware family names	Type	Behavior Summary
NOROBOT	DLL (Dropper / Loader)	- Dropped by the COLDCOPY HTML ClickFix lure. - Executed via rundll32.exe. - Acts as a first-stage payload that downloads and executes the next stage (either YESROBOT or MAYBEROBOT). - Evolving delivery chain: initially simplified, later reintroduced split crypto keys to evade detection. - Used selectively on high-value, likely pre-compromised targets.
YESROBOT	Python Backdoor	- Minimalist implant deployed briefly in late May 2025. - Communicates over HTTPS to a hard-coded C2 server. - Supports: Download & execute files, Exfiltrate documents of interest - Only 2 instances observed (over ~2 weeks). - Likely a rush "stopgap" after LOSTKEYS exposure. - Required full Python 3.8 installation — noisy and abandoned quickly.
MAYBEROBOT	PowerShell Implant	- More mature and extensible than YESROBOT. - Replaced YESROBOT as the primary payload. - Capabilities: Download and run payload from URL, Execute commands via cmd.exe, Run arbitrary PowerShell code - Also known as: SIMPLEFIX (Zscaler ThreatLabz). - Deployed after NOROBOT; used for persistent intelligence collection
COLDCOPY	HTML ClickFix Social Engineering Lure	- Mimics CAPTCHA verification. - Tricks user into pasting and running malicious PowerShell via Windows Run dialog (Win + R). - Drops and triggers NOROBOT DLL → starts the ROBOT infection chain.

Summary Table:

Malware	Type	KEY Behaviors
COLDCOPY	HTML Lure	Fake CAPTCHA to PowerShell Via Run dialog
NOROBOT	DLL dropper	rundll32.exe to downloads YESROBOT or MAYBEROBOT
YESROBOT	Python BAcckdoor	HTTPS C2, file exfil, Short-lived stopgap
MAYBEROBOT	PowerShell Implant	Flexible: Run URL payloads, cmd, PS Code

Enrich each family:

COLDCOPY:

What does it do?

COLDCOPY is a malicious HTML file disguised as a CAPTCHA verification page. When opened, it tricks the user into copying and pasting a long PowerShell command into the Windows Run dialog (Win+R) to "fix" a fake error — actually launching the attack.

How does it spread?

It spreads via phishing emails or malicious links. The victim downloads and opens the HTML file (often named something like verify.html), which displays a fake CAPTCHA prompt with instructions to press Win+R, paste the code, and hit Enter.

What kind of damage does it cause?

It serves as the entry point for the entire ROBOT malware chain. Once the PowerShell runs, it downloads and executes NOROBOT, enabling full system compromise, data theft, and persistent spying on high-value targets.

NOROBOT:

What does it do?

NOROBOT is a malicious **DLL** file dropped onto the victim's computer. It's executed using Windows' built-in `rundll32.exe` tool and acts as a launcher — downloading and running the next malware stage (either **YESROBOT** or **MAYBEROBOT**).

How does it spread?

It doesn't spread on its own. It's delivered by the **COLDCOPY HTML lure** after the user pastes and runs the malicious **PowerShell** command via the Run dialog.

What kind of damage does it cause?

It enables **initial code execution** and **persistence**. By abusing a trusted Windows tool (`rundll32`), it bypasses many defenses and paves the way for advanced backdoors used to steal intelligence from diplomats, journalists, and dissidents.

YESROBOT:

What does it do?

YESROBOT is a lightweight Python-based remote control tool. It connects to a hacker-controlled server over **HTTPS**, waits for commands, and can download files, run programs, or steal specific documents.

How does it spread?

It's deployed by **NOROBOT** in the early versions of the attack (late May 2025). Only **two infections** were ever observed — it was quickly replaced.

What kind of damage does it cause?

It gives attackers **direct remote access** to steal sensitive files and maintain a foothold. Its noisy nature (installing full Python) made it easy to detect, so it was abandoned after two weeks.

MAYBEROBOT:

What does it do?

MAYBEROBOT is a flexible **PowerShell** implant that lives in memory. It can run system commands, download and execute new tools from the internet, and send results back to the attackers — all using encrypted communication.

How does it spread?

Deployed by **NOROBOT** after the initial **COLDCOPY** lure succeeds. It's been active from **June to September 2025** and is now **COLDRIVER's** main post-exploitation tool.

What kind of damage does it cause?

It provides **long-term covert access** for espionage. Attackers use it to run reconnaissance, steal documents, and deploy additional malware — targeting NGOs, policymakers, and Russian dissidents.

COLDRIVER Malware Chain – Final Summary

Russian state hackers (COLDRIVER) are rapidly evolved their toolkit after Google exposed **LOSTKEYS** in May 2025. They shifted from credential theft to a **multi-stage ClickFix attack chain**:

1. **COLDCOPY (HTML lure)** → Fake CAPTCHA tricks users into running PowerShell via **Win+R**.
2. **NOROBOT (DLL dropper)** → Launched via `rundll32.exe` , downloads next stage.
3. **YESROBOT (Python backdoor)** → Short-lived (2 cases), replaced due to noise.
4. **MAYBEROBOT (PowerShell implant)** → Current payload; flexible C2, in-memory, persistent.

Goal: Long-term espionage on **NGOs, journalists, dissidents, and policymakers**.

Tactics: Social engineering + living-off-the-land (PowerShell, rundll32).

Status: Active and evolving — **no IPs/hashes public**